Chapter 15 exercises • Security

OS15-E01 • Bounds and defense limits

A 12-byte C-string buffer receives 12 data bytes; no particular ABI layout is assumed.

1. How many bytes including NUL are needed? Give reject/truncate contracts.
2. Can NX prevent this overflow?

OS15-E02 • Pending-slot denial of service

In a finite steady state, each accepted incomplete request occupies a slot for an average of 8 s without early cleanup. The mean number occupying the same system boundary is 2000.

1. Find the mean accepted request rate by Little’ s law. Does it determine the offered arrival rate or first saturation time?
2. Who can suffer from source-IP limits?

OS15-E03 • Reused keystream

m1=0x10, m2=0x70, s=0xA5, c=m XOR s.

1. Compute ciphertexts, their XOR, and recovery of m2 from known m1.
2. Does this require brute-force cipher breaking?

OS15-E04 • Non-coprime RSA plaintext

p=5, q=11, n=55, e=3, d=27, m=5.

1. Encrypt/decrypt with a square table.
2. Why does correctness hold despite gcd(5,55)≠1?

OS15-E05 • Hashes, MACs, and replay

Compare (m, H(m)), (m, MACk(m)), and a MAC over an unambiguous encoding of session, message m, and a unique pending nonce. Assume an uncompromised key and a secure MAC.

1. Why does a public hash not authenticate, and a MAC not inherently prevent replay?
2. How do two threads avoid double acceptance? Does nonce consumption alone ensure exactly-once external payment?

OS15-E06 • Historical TLS identity and secrecy

A network adversary records a full TLS 1.2 handshake using static RSA key exchange, including ClientKeyExchange and hello randoms. The client validates the trust chain, name, and usage, then verifies server Finished. Two years later the static RSA private key leaks.

1. Does a valid certificate signature alone prove current private-key possession?
2. Does deleting traffic keys necessarily protect the old session?

OS15-E07 • Salt and guess cost

500 records have distinct salts, 20000 dictionary candidates each, and 2 ms/KDF on one serial work unit.

1. Give full-dictionary computation/time. Must salt be secret?
2. Does an online limit of one guess/account/s change offline time to 10000000 s?

OS15-E08 • IDS base rate

There are 100000 events, attack fraction 0.001, TPR 0.9, FPR 0.01. Counts below are expectations; define precision as the population conditional probability P(attack | alarm).

1. Find expected TP, FN, FP, TN and population precision. Must this equal the expected random finite-sample ratio TP/(TP+FP)?
2. At the same TPR/base rate, bound FPR for at least50% precision.

OS15-E09 • Firewall permissions

Use first-match rules: tracked established traffic, new Internet→web TCP 443, new web→DB TCP 5432, then deny. The first three packets below start new connections with no existing state; the final DB→web reply matches the reverse five-tuple and state of an allowed connection.

1. Evaluate new Internet→DB TCP 5432, new web→DB TCP 5432, new web→DB TCP 22, and the described reply.
2. Can a compromised web server still reach DB?

OS15-E10 • Windows 7 DACL and MIC

Use disjoint specific r/w access masks after generic mapping. Exclude owner, privilege, restricted-token, and other mandatory exceptions. Token user SID is U and group SID G is enabled for the relevant ACEs; token IL is low, object IL medium, and mandatory policy is only NO_WRITE_UP.

1. Evaluate requests r and rw under [deny(G, w), allow(U, rw)].
2. Deliberately put allow first. What does DACL decide for rw, and what is the final write decision?
3. Distinguish NULL and empty DACLs.

References and attribution

Lin Cing, handwritten operating systems notes. Silberschatz et al., Operating System Concepts, 9th ed., Ch. 15. RFC 5246. RFC 7568. Microsoft: DACL. Microsoft: MIC.

Original educational synthesis by Lin Cing, licensed under CC BY 4.0.
https://github.com/xinhi6716/computer-science-self-study

Lin Cing
https://github.com/xinhi6716/computer-science-self-study